

Article Type	Process
Article #	000092778
Title	OPC DCOM Security: A Guide for the Perplexed
Confidence	Expert Reviewed
Published on	3/10/2020
Last updated on	2/15/2022

! This article is only available for AVEVA employees.

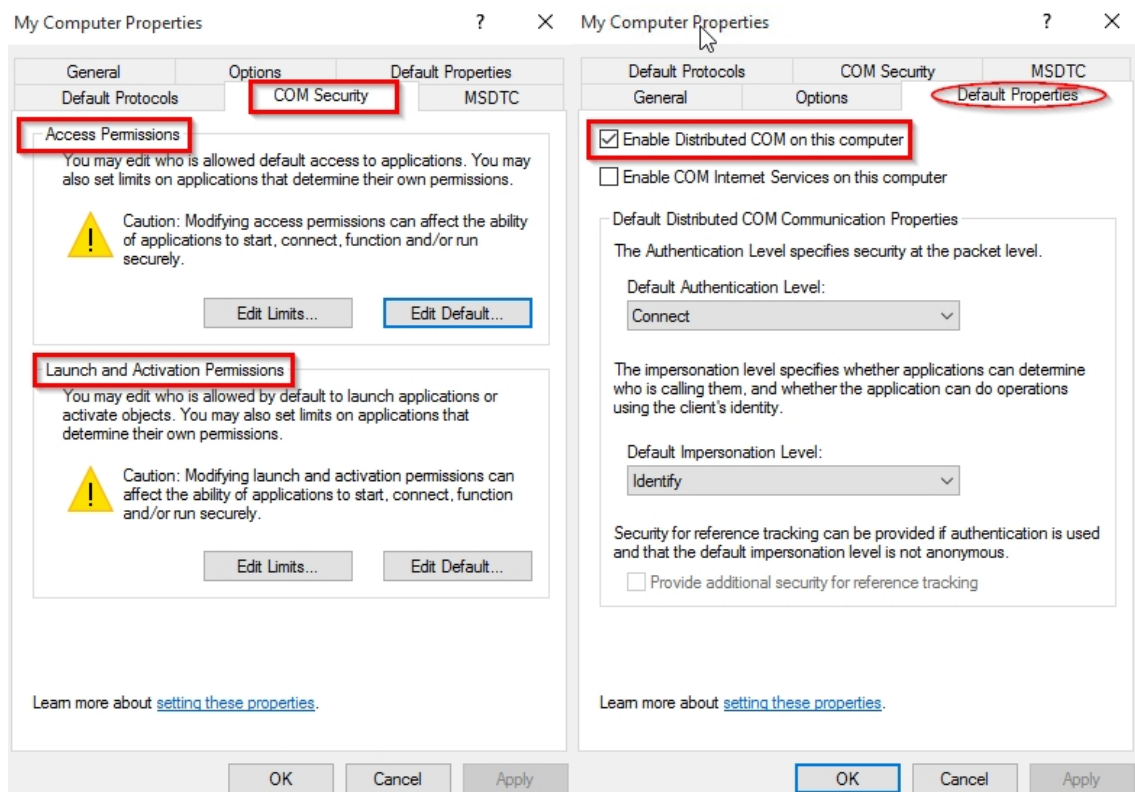
Using a local OPC Server

This statement is an urban legend: "If the OPC Server is installed and runs on the same machine as the interface, DCOM security is not needed or used". **While that is usually the case, COM security is still in effect and can impact interface operation!**

The acronym DCOM stands for "distributed COM"; which simply allows COM to work from one machine to a different machine. COM security is still in play, even when the OPC Server and OPC interface are run on the same computer. It just so happens that in most cases, COM (ie DCOM) security settings and ACLs will, by default, allow the interface to work without changing anything.

DCOM itself can be disabled if the OPC Server and interface are on the same machine, but COM security still applies. ****WARNING**** disabling DCOM affects all DCOM objects system wide and should never be done unless the user is confident that it will not affect other applications. This is from Microsoft: "Disabling DCOM on a computer has no effect on local COM objects. COM still looks for launch permissions that you have specified. If no launch permissions have been specified, default launch permissions are used. Even if you disable DCOM, if a user has physical access to the computer, they could launch a server on the computer unless you set launch permissions not to allow it.", reference here: [Setting System-Wide Security Using DCOMCNFG](#)

The following screenshots are taken from the DCOMCNFG utility at the computer level. Note the tab on the left that says "COM Security"; it does not say "DCOM security", even though those settings affect both COM and DCOM access. The tab on the right applies to DCOM only and allows enabling/disabling DCOM and also setting packet level authentication and impersonation level.



Windows Authentication

Before you jump into DCOM config and troubleshooting, you must ensure that Windows Authentication works between the interface machine and the OPC Server machine, in both directions, using the credentials that are used by the interface/OPC Server. Have you done that? Just because the credentials match on both machines does not mean that authentication is happening.

A quick test to determine if Windows Authentication is working is to perform a simple file-sharing request from the interface/client machine to the OPC server machine **and** vice-versa. It must be tested in both directions:

1. Login to the machine using the credentials used by the OPC interface/server. Can't login as the user interactively? You can use a RUNAS to run Windows Explorer, if you cannot login to the machine:

```
runas /user:domain\user "explorer /separate"
```

If you encounter problems:

1. take ownership of reg key HK_CLASSES_ROOT\AppID\{CDCBCFCA-3CDC-436f-A4E2-0E02075250C2}, and grant yourself Full Control. This key controls how Explorer is allowed to launch
2. rename the subkey from runas to _runas. If you receive an error doing this, then you probably didn't complete step one correctly

Once this is changed, you can launch Explorer with a different set of credentials via the **runas** command.

From command prompt, you can then launch Explorer:

- with runas
 - runas /user:domain\username "c:\windows\explorer.exe /separate"
 - followed by completing the password prompt.

2. If logged in interactively as the user, choose start->run

3. In the textbox (or explorer window if using RUNAS) , type \\computername and hit enter key

If successful, you will get a window. If you have no access to shares/files on the computer, the window will be empty; otherwise it will contain shares/folders/files you have access to.

If it **fails for any reason** (eg. you get prompted for credentials, you get an error, it times out, etc...), then you must resolve the issue! ***warning*** If it does authenticate, that does not mean it authenticated as the user you logged in with; proceed to step 3 below before moving to DCOM troubleshooting below.

Things to check if authentication fails:

1. Windows NT: If Windows NT is involved, you may need to add the IP address of the NT machine and the credentials to the Credentials Manager (CM) on the non Windows-NT machine. Search the web for running the CM on your version of the Windows OS.

2. NTLM and File-sharing changes: in Windows Server 2008, Windows 7 and later, significant changes were implemented so see: [Configuring NTLM authentication for OPC](#)

3. Simple File Sharing: just because authentication is successful does not mean it authenticated as the user that initiated the request:

Beginning in Windows XP, a computer configured for workgroup operation defaults to Simple File Sharing mode. In this mode, the "guest" account is enabled, and all access to the computer is done anonymously. This mode affects DCOM server access as well as network sharing, and must be disabled in order for OPC connections to work.

To disable Simple File Sharing (on both machines if the OPC Server is remote):

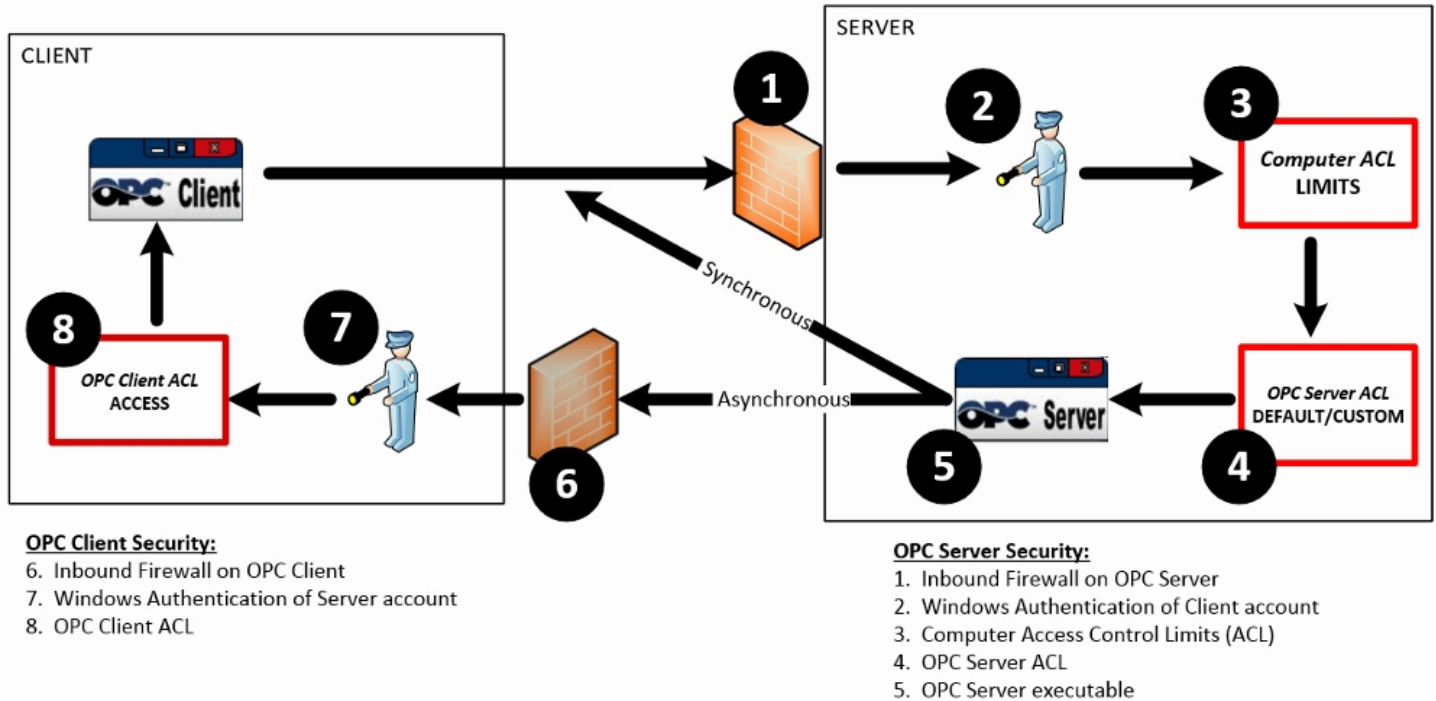
1. In the Windows Control Panel, select *Administrative Tools...Local Security Policy*.
2. Select *Security Settings...Local Policy...Security Options*.
3. Select "Network Access: Sharing and security model for local accounts".
4. Set it to "Classic: Local users Authenticate as themselves".

4. Check the Windows event log (on both machines if the OPC Server is remote): NOTE: logon auditing must be enabled: [Windows Security Auditing](#)

Search for event 680 and the following error codes:

0xC000006A An incorrect password was supplied.
 0xC000006F The account is not allowed to log on at this time.
 0xC0000064 The account does not exist.
 0xC0000070 The account is not allowed to log on from this computer.
 0xC0000071 The password has expired.
 0xC0000072 The account is disabled.

DCOM Basics



All current OPC servers and clients are based on Microsoft's COM/DCOM technology. COM (Component Object Model), provides a set of interfaces (object oriented programming interfaces) that allow software components to communicate on a single node. DCOM (Distributed Component Object Model) is the network communication protocol that extends the COM model to allow software components to communicate across networked nodes. Because DCOM allows programs on one computer to execute code on another, it has significant security implications. Many of the security enhancements in Windows XP SP2 and Server 2003 are actually new restrictions to DCOM.

The following discussion refers to DCOM servers and clients. OPC servers are DCOM servers, and OPC clients are DCOM clients, but the roles are not fixed. An OPC server will at times operate as a DCOM client, and vice-versa. The OPC interface retrieves data from the OPC server using asynchronous callbacks. When the OPC server calls into the interface, the interface acts as a DCOM server. For this reason, DCOM security needs to be configured on both the interface and OPC server nodes.

DCOM security is implemented on several levels:

- System-level settings and policies that define the minimum level of security for all DCOM components.
- Default security levels that are used if a DCOM component does not explicitly set a security level.
- Custom security levels specified for individual DCOM servers using dcomcnfg.
- Custom security implemented in code by the DCOM server (CoInitializeSecurity).

At all levels, the configuration parameters are the same.

Authentication levels determine how strictly security is checked. An authentication level of NONE allows anonymous access to the DCOM server. Authentication levels CONNECT, CALL, PKT, PKT_INTEGRITY, and PKT_PRIVACY require authentication, and provide increasing levels of security including packet encryption. Higher authentication levels have significant processing overhead, so levels higher than CONNECT are seldom used in OPC applications.

Impersonation levels determine how a client's credentials can be used by a server. Impersonation is usually not relevant to OPC.

Access lists (ACLs) determine which users and groups are allowed to connect to a DCOM server. Unless the authentication level for a DCOM

server is set to NONE, the user account associated with the DCOM client process is compared to the ACL for the server. The DCOM client can only access the DCOM server if the account for the client process (or a group that includes that account) is included in the list with appropriate permissions. When the server and client are on the same computer, local accounts may be used in the lists. If server and client are on separate nodes, domain accounts should be used if the nodes are in the same domain. Special configuration of identical local accounts is needed if the two nodes are not in the same domain.

Before you begin configuring DCOM, you should determine the accounts that will be used by the OPC server and the OPC interface. OPC servers are generally configured to run under a specific service account, and you should have all information about that account, including the password. You should configure a service account for use by the OPC interface. The account password should be set so that it does not expire. In the discussion that follows "OPCUser" is the OPC service account

The user account associated with a process can be set in several ways:

- For interactive programs such as the PI OPC Client, the account will be the same as that of the user running the program. You can also run a program under a different account using the Windows "runas" command.
- For programs that run as Windows services, the account will be the one specified in "Logon" tab in the Services Control Panel.
- The user account for a DCOM server is specified in the "Identity" tab in dcomcnfg. If the DCOM server runs as a Windows service, the account specified as the DCOM identity should be the same as the one specified in the Services Control Panel logon. If different accounts are used for the service and DCOM, or if the DCOM identity is set to "launching user", multiple instances of the server will be launched.

Several built-in Windows account groups must be included in the access control lists. Our documentation states that NETWORK, INTERACTIVE, and SYSTEM must be included in the ACLs. This is not strictly true, so long as none of these groups are included with "deny" permissions; all that is required is that the specific user (or any group that includes that user) be included in the access control lists. The "Everyone" group may be included in access lists, but the accounts included in the "Everyone" group are different on different versions of Windows

Asynchronous vs Synchronous

Between an OPC Client and OPC Server, there are some functions that can get executed synchronously and others that are executed asynchronously. Asynchronous calls are more complicated and involve the OPC Server communicating back to the OPC Client whenever a task is completed.

Examples of Synchronous calls:

- Connecting to the server
- Creating a group
- Adding tags
- Clicking "Sync Read" in OPC Client tool (Note - PI OPC DA Interface doesn't ever do a Sync Read, but there is a button for it in the client tool.)

Examples of Asynchronous calls:

- Reading data with the Refresh, Poll, or Advise button on the client tool
- Reading data with the Interface

In the above DCOM diagram, Asynchronous calls have to go through steps #6-7-8, while the synchronous calls do not. That is how sometimes it is possible to connect and items to a group, but not click Poll or Advise to get data. As for PI OPC DA Interface, if the Asynchronous calls are not working due to DCOM settings on the OPC Client machine preventing the OPC Server from communicating back to the OPC Client, then it will not be possible to get data through the Interface and you can see error 80007005 (access denied) which stem from steps #7-8, or error 8000706ba which would be step #6.

Bitness

If you are using a 64-bit Windows machine and need to see the 32-bit DCOM data (for 32-bit DCOM servers), run the 32-bit DCOMCNFG utility:

```
mmc /32 %windir%\syswow64\comexp.msc
```

Using RunAs

It is a good idea to test OPC connections when running programs under the service account that will be used to run the interface. If you are not logged onto the computer with the same account as the one the interface is configured for, you'll need to use the Runas command to change the user running the OPC client/interface program. In Windows XP/2003 this can be done simply by right-clicking the executable and selecting "Run as..." from the popup menu. For Windows 2000, create a shortcut to the exe and then in the shortcut properties the running user can be changed. The below commands may also be used to run a program under a different user.

Running an executable:

```
Runas /user:OPCUser OPCClient.exe
```

Running the batch file requires a little trick:

```
Runas /user:OPCUser cmd opcint.bat
```

Differences in DCOM security beginning with Windows XP/Windows Server 2003

Microsoft made significant changes to DCOM security in releases of Windows beginning with WinXP and Win2003. These changes include new system policies and more restrictive default settings which complicate configuration of OPC components.

“Everyone” is not everyone

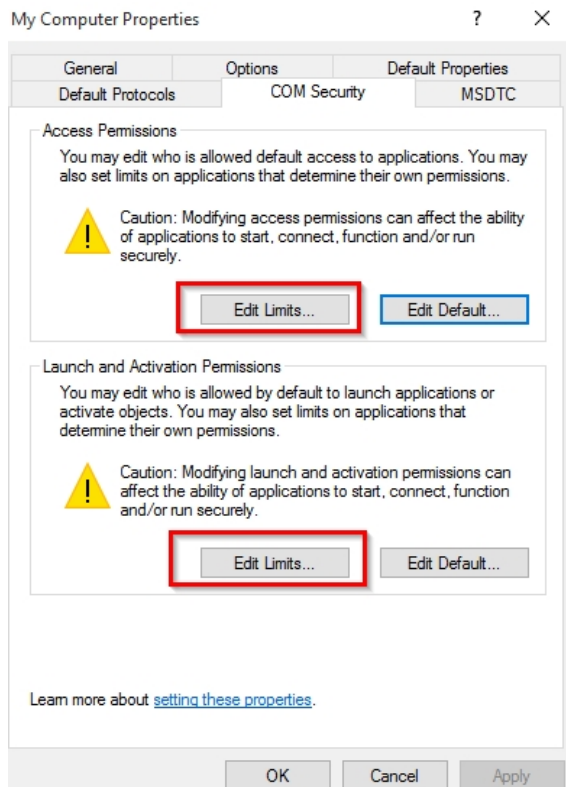
The “Everyone” group – In Windows NT/2000, “Everyone” includes both authenticated and unauthenticated users. For these versions of Windows, “Everyone” should be included in access control lists for DCOM components with an authentication level of NONE. Beginning in Windows XP/2003 and beyond, “Everyone” only includes authenticated users. For unauthenticated access to a DCOM server, the “Anonymous Logon” group must be included in access control lists in addition to “Everyone”.

New policies to make your life miserable

1. In the Windows Control Panel, select *Administrative Tools...Local Security Policy*.
2. Select *Security Settings...Local Policy...Security Options*.
3. Select “System Objects: Default owner for objects created by members of the Administrators group”. Verify that it is set to “Administrators group”

Systemwide COM Limits

Windows XP SP2 and Server 2003 now include system wide limits on DCOM access. These are intended to prevent badly coded or misconfigured DCOM servers from compromising the security of the system by limiting access and launch permissions. These new limits don't usually cause problems for the interface or the client tools, because the Everyone group is included in the ACLs by default. However, the limits must be changed in order for OPCEnum to work with Anonymous access, and may also need to be modified if an OPC server does not run as a service. Here is a screenshot:



Anonymous Access and OPC Enum

Oftentimes when customers run the OPC client, or the ICU, interactively, they are using credentials that are different than the interface' service credentials. These credentials might be be unauthenticated on the OPC Server machine, and therefore considered anonymous access. When that happens, OPC Enum on the OPC Server machine cannot be accessed to list the OPC servers that exist on the server machine. To allow anonymous access in that situation, the Anonymous group must be configured on the OPC Server for OPC Enum to work.

In Windows Server 2003 and higher, if the client is not authenticated to the server (ie. using anonymous access) AND the Everyone policy* is disabled (see below), the following must be performed on the OPC Server machine to allow anonymous access to OPC Enum:

1. Configure the Access and Activation Limits ("Limits" only exist at the computer level in DCOMCNFG) for "Anonymous" to allow Local Access/Activation and Remote Access/Activation. Limits enforce system wide "limits" on the COM servers that reside on that machine. To allow anonymous access to OPC Enum, these limits must be set.
2. Add Access/Activate Permissions, both Local Access/Activate and Remote Access/Activate, for "Anonymous" principle. This can be done at the computer level or at the OPCEnum server level. NOTE: changing limit and computer level access/activation permissions will affect every server on the machine that uses the default COM permissions and we strongly recommend against changing them! Having said that, if computer level permissions are desired, change the access/activate permissions at the computer level and configure OPCEnum's Access/Activate Permissions to "Use Default"; otherwise, configure the access/activate permissions at the OPCEnum level using Customize. For an unauthenticated user to use OPC Enum, the OPC Enum service must be running and configured for Automatic Startup. OPC Enum can technically be launched without running as a service, but it is ill-advised to allow Anonymous access in system-wide machine limits for Remote Launch and Activation. "Anonymous Logon" does not need remote launch permissions provided that OPCEnum is configured as an automatic service.

*The Everyone Policy

Network access: Let Everyone permissions apply to anonymous users

By default, the Everyone policy is disabled, and we strongly recommend that it remain disabled.

New COM Permissions

Windows NT and 2000 support permissions for 3 different actions: access, launch, and configure. Windows XP/2003 supports an additional action, activation, and also provides separate local and remote permissions for each action.

The access and configure actions are essentially the same in both older and newer versions of windows. Access means the permission to execute a function call to a DCOM server. Configure means the permission to change the configuration of a DCOM server (by default, only administrators have permission to configure a component).

In Windows XP/2003, the older launch action has been split into separate launch and activation permissions. The launch action now means strictly the ability to start a DCOM server process. The activation action means obtaining a pointer to a DCOM interface. These changes are designed to allow a client to use a DCOM server while preventing the client from starting a new process. Thus, launch permission is not needed in order for a client to access a server that runs as an automatic Windows service.

In general, the service account used to run the OPC interface will require access and activation permissions, plus launch permissions if the OPC server is not implemented as a service. Remote permissions must of course be granted if the interface node is separate from the OPC server node.

Dynamic Port Allocation

refer to the following wiki for info on ports that must be open and the process DCOM uses to select TCP ports: [Configuring ports for DCOM for use with the OPC Interface. NAT and Firewall considerations](#)

Troubleshooting DCOM Security Problems

Windows Security auditing

As a first step towards diagnosing DCOM communication problems, enable Windows security auditing on both the OPC server and interface nodes.

To do this, run the Local Security Policy administrative control panel and select Security settings->Local policies->Audit policies :



"Audit account logon events", "Audit logon events", and "Audit object access" should all be set to log failures. Failure events will appear in the Windows security log. On Windows XP SP2 and 2003 computers, the logs will also contain events generated by the Windows Firewall, even if it is disabled; these events can provide additional clues to DCOM failures.

Sample Windows security log events on the Client Node. This event indicates a failed logon due to an unknown user name. A failed logon due to a bad password will be identical, except the error code will be 0xC000006A:

```
Event Type: Failure Audit
Event Source: Security
Event Category: Account Logon
Event ID: 680
Date: 10/16/2007
Time: 5:20:48 PM
User: NT AUTHORITY\SYSTEM
Computer: OPCLAND
Description:
Logon attempt by: MICROSOFT_AUTHENTICATION_PACKAGE_V1_0
Logon account: opcaccount
Source Workstation: ONELOVE
Error Code: 0xC0000064
```